

Introduction

L a b S e s s i o n 9 C o d e Q u a l i t y A n a l y s i s

Code quality refers to the degree to which source code is written in a way that meets both functional and non-functional requirements, as well as best practices for readability, maintainability, efficiency, and reliability. High-quality code is:

1. **Readable:** Easy to understand for other developers, reducing time spent on code reviews and debugging.
2. **Maintainable:** Written in a way that changes can be easily made in the future without introducing bugs.
3. **Reliable:** It performs as expected with minimal risk of errors.
4. **Efficient:** It utilizes resources effectively, avoiding unnecessary computations.
5. **Consistent:** Adheres to established coding standards and guidelines.

Code Quality Tools

Several tools are available to help developers assess the quality of their code. Some common code quality tools include:

- **SonarQube**
- **ESLint** (for JavaScript/TypeScript)
- **Pylint** (for Python)
- **Checkstyle** (for Java)
- **Codacy**
- **PMD** (for Java)

These tools provide static analysis of the source code, detecting issues such as code smells,

potential bugs, security vulnerabilities, and deviations from coding standards.

Using SonarQube for Code Quality

In this lab, we will use **SonarQube** to check and improve code quality. It will help identify issues early, enforce coding standards, and ensure that our software is reliable and maintainable. By integrating SonarQube into our CI/CD pipeline, we can perform automated code quality checks every time code is committed or merged, maintaining high standards throughout the development lifecycle.

What is SonarQube?

SonarQube is an open-source platform that continuously inspects the quality of source code and provides comprehensive reports on its health. It helps teams write cleaner and safer code by identifying

1. **Bugs:** Issues in the code that may lead to incorrect behavior.
2. **Vulnerabilities:** Potential security risks in the source code.
3. **Code Smells:** Poor code practices that can lead to maintainability problems.
4. **Duplications:** Repeated code blocks that increase the maintenance burden.
5. **Test Coverage:** The extent of the code covered by automated tests.

SonarQube uses **static code analysis** to detect issues without running the code. It assigns severity levels to issues, ranging from minor to blocker, and generates a **Code Quality Report** with detailed insights, helping developers prioritize and fix problems early in the development process.

Getting Started with SonarQube Cloud

SonarQube Cloud, also known as **SonarCloud**, is a cloud-based code quality and security tool that integrates with popular DevOps platforms like GitHub, GitLab, Bitbucket, and Azure DevOps. It offers a comprehensive analysis of your projects, providing real-time feedback on code quality, helping you identify bugs, vulnerabilities, and code smells, and enforcing clean code standards.

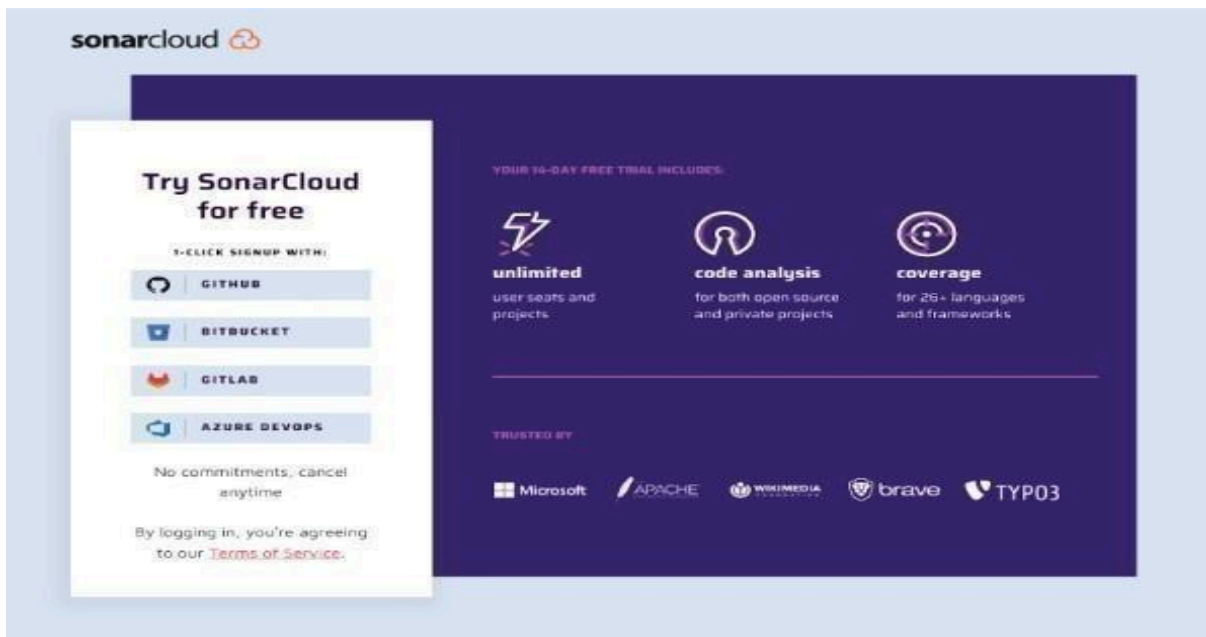
Here's a detailed step-by-step guide on how to get started:

Step 1: Sign Up and Integrate with Your Development Platform

To get started with SonarQube Cloud, visit the SonarCloud Sign Up page. Create an account using your preferred DevOps platform:

- **GitHub**
- **GitLab**
- **Bitbucket**
- **Azure DevOps**

By connecting your DevOps account, SonarQube Cloud will link directly to your repositories, allowing seamless integration. You can choose your GitHub organization or personal account for setup



Step 2: Set Up Your Organization in SonarQube Cloud

Once you've connected your DevOps account, the next step is to create or select an organization in SonarQube Cloud:

- **Create a New Organization:** You can start fresh by setting up a new organization in SonarQube Cloud.
- **Import an Existing Organization:** If you already have an organization in your GitHub or GitLab account, you can import it directly. The imported organization will automatically include all members from your DevOps platform.

Welcome to SonarCloud

Start by importing or creating an organization

Import projects from a GitHub organization that already have the SonarCloud app installed

 manish-kapur Import >

Or install the SonarCloud app on another of your GitHub organizations

 Import another organization from GitHub

Just testing? You can [create projects manually](#)

Disclaimer: SonarCloud requires only the necessary permissions for the best analysis results. Your organization and code will always be secure. Find more information on our [security and compliance centre](#) .

Join an organization

Now that you have an account on SonarCloud, just ask the Organization Administrator to add you manually.

[Learn More](#) 

Step 3: Choose a Plan

SonarQube Cloud offers both free and paid plans:

- **Free Plan:** This is suitable for public repositories and includes basic code analysis features.
- **Paid Plan (14-Day Trial):** This plan is required for analyzing private repositories. You can start a no-commitment 14-day free trial. A credit card is required for the trial, but you won't be charged until the trial ends. Pricing is based on the number of Lines of Code (LOC) analyzed.

During the trial, you get access to all features, including advanced code analysis, Quality Gates, and detailed reporting.

2 Choose a plan

The screenshot shows two plan options for SonarQube Cloud:

- Free plan 0 €**
 - All projects you analyze will be public.
 - Anyone can browse source code.
 - Any code that has changed since the previous version is considered new code.
- Paid plan from 10 € / month**
 - ✓ Unlimited private projects
 - ✓ Strict control over who can view your private data
 - ✓ No commitments, cancel anytime
 - ✓ 14 days free trial.
 - [Learn more](#)

Step 4: Import and Analyze Your First Repository

Once your organization is set up, it's time to import your projects:

1. Navigate to your organization's **Projects** tab in SonarQube Cloud.
2. Select the repositories you want to analyze from your GitHub, GitLab, Bitbucket, or Azure DevOps account.
3. Click **Set Up** to start the configuration.

Step 5: Run Your First Code Analysis

SonarQube Cloud offers two methods for running code analysis:

- **Automatic Analysis:** This method triggers analysis automatically when code is pushed to your repository.
- **CI-Based Analysis:** For greater control, you can integrate SonarQube Cloud with your CI/CD tool (e.g., GitHub Actions, GitLab CI/CD). This method allows you to run analysis during your build process using sonar-scanner.

Example GitHub Actions workflow: name:

Code Quality Analysis

on: [push,

pull_request] jobs:

sonarQubeScan:

runs-on:

ubuntu-latest steps:

- uses: actions/checkout@v3

- name:

Run

SonarScanner

run:

sonar-scanner

This setup ensures that every new pull request and push is analyzed automatically, providing immediate feedback.

Step 6: Explore the SonarQube Cloud Dashboard

After the first analysis is complete, visit the **SonarQube Cloud dashboard** to review the results. Here's what you can find:

- **Bugs, Vulnerabilities, Code Smells:** See a list of issues detected in your code, along with recommendations for fixing them.
- **Code Coverage:** View the percentage of your code that is covered by tests, helping you identify areas that need more testing.
- **Quality Gate Status:** Check if your project passes the defined Quality Gate criteria, which include thresholds for code coverage, bugs, and vulnerabilities.

Spend time familiarizing yourself with these metrics to prioritize your code quality improvements effectively.

The screenshot shows the SonarCloud web interface for a project named "KANZA MUHAMMAD AKRAM". The main section is titled "Main Branch Summary" and shows a "Quality Gate" status of "Passed". Below this, there are several metrics displayed in a grid:

- Security:** 0 Open Issues (Grade A)
- Reliability:** 570 Open Issues (Grade E)
- Maintainability:** 2.7k Open Issues (Grade C)
- Accepted Issues:** 0
- Coverage:** 0.5% (Note: A few extra steps are needed for SonarCloud to analyze your code coverage. Link: [Set up coverage analysis](#))
- Duplications:** 0.5% (Note: No conditions set on 10k lines)

The left sidebar contains navigation links: Overview, Main Branch, Pull Requests (0), Branches (1), Information, and Administration. The top navigation bar includes "My Projects", "My Issues", and "Explore". A warning banner at the top right states: "The last analysis has a warning. [See details](#)".

Step 7: Dive Into the Issues and PR Analysis

- When you create a pull request, SonarQube Cloud analyzes the changes and provides feedback right in the PR interface.
- Issues detected in the pull request are displayed, and the quality gate status is shown. If the code does not meet the defined criteria, the pull request can be blocked from merging.

My ProjectsMy IssuesExplore

KANZA MUHAMMAD AKRAM > SolarOps > main

SummaryIssuesSecurity HotspotsMeasuresCodeActivity

Filters

Clear All Filters

Clean Code Attribute

Consistency517

Intentionality1.6k

Adaptability630

Responsibility0

Software Quality

Security0

Reliability570

Maintainability2.7k

Add to selection

Ctrl + click

Severity

Blocker0

High702

Medium1.9k

Low149

Info0

Bulk Change

Select Issues

Navigate to issue

2,703 issues47d effort

node_modules/flatted/php/flatted.php

Consistency

Add a new line at the end of this file.

convention

OpenKANZA MUHAMMAD AKRAMMaintainabilityCode SmellMinor1min effort26 days ago

Consistency

Remove the useless trailing whitespaces at the end of this line.

conventionpsr2

OpenKANZA MUHAMMAD AKRAMMaintainabilityCode SmellMinor1min effort26 days ago

Intentionality

Add curly braces around the nested statement(s).

pitfall

OpenKANZA MUHAMMAD AKRAMMaintainabilityCode SmellCritical2min effort26 days ago

Intentionality

Add curly braces around the nested statement(s).

pitfall

OpenKANZA MUHAMMAD AKRAMMaintainabilityCode SmellCritical2min effort26 days ago

Intentionality

Add curly braces around the nested statement(s).

pitfall

OpenKANZA MUHAMMAD AKRAMMaintainabilityCode SmellCritical2min effort26 days ago

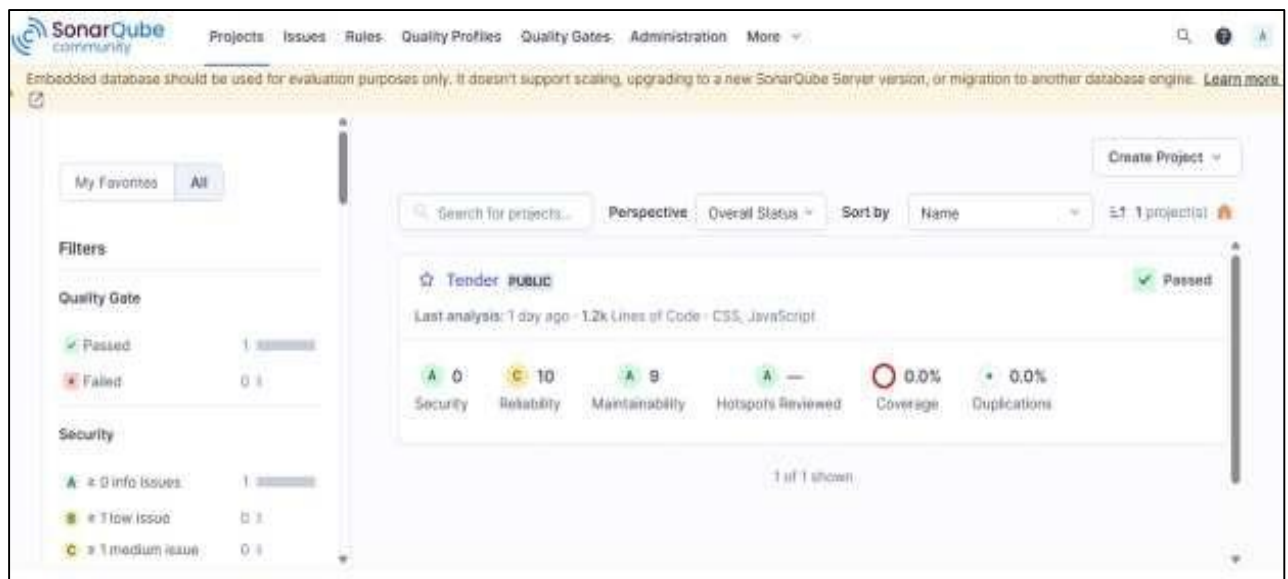
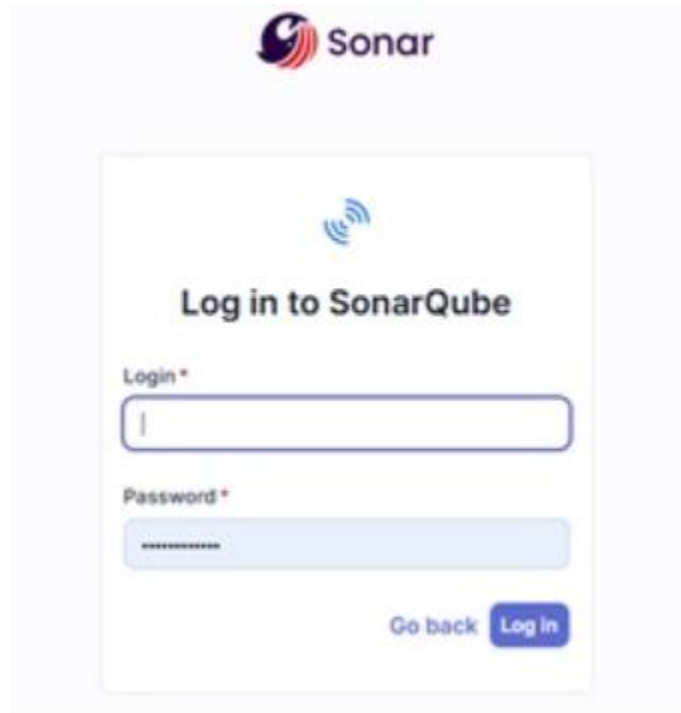
The last analysis has a warning. [See details](#)

EXERCISE

Analyze any existing GitHub project using SonarQube Cloud. Perform a full code quality analysis and capture screenshots of your findings, including code smells, bugs, vulnerabilities, maintainability, reliability graphs, and coverage. Document all your observations, summarize the issues, and suggest improvements in a brief report.

Task 1

Install and configure SonarQube on your local machine. Take a screenshot of the dashboard after successful setup.



Task 2

Choose any existing project and run a SonarQube analysis. Identify and categorize the issues found (e.g., bugs, code smells, vulnerabilities). Attach printouts.

- No Bugs Found
- No Vulnerabilities
- Code smells: 16

